



CYBER SECURITY

PRACTICAL GUIDE

Name: Chandana Somanath Khatavakar

Local File Inclusion (LFI)

Local File Inclusion (LFI) is a web vulnerability that allows attackers to include files on a server through the web browser. This vulnerability occurs when an application does not properly validate user input and allows the attacker to manipulate paths, gaining access to unauthorized files on the system. The severity of LFI varies depending on the files accessible and the security posture of the server.

Using **Burp Suite** with an **OWASP vulnerable machine** (like OWASP Juice Shop or OWASP Broken Web Applications) to identify and exploit an **LFI (Local File Inclusion) vulnerability** can be a hands-on way to understand how these vulnerabilities work and how to detect them in real-world applications. Here's a step-by-step guide on how to approach this setup.

Prerequisites

1. **OWASP Vulnerable Machine:** Set up the machine in a virtual environment or a cloud lab environment.
2. **Burp Suite:** Download and install Burp Suite Community or Professional Edition on your Kali Linux machine.
3. **Web Browser Configuration:** Configure your browser to route traffic through Burp Suite's proxy (default is usually 127.0.0.1:8080).

Step-by-Step Guide to Finding and Exploiting LFI

1. Identify Potential LFI Points

- Start Burp Suite and ensure your browser proxy is set up to intercept traffic.
- Browse through the web application (OWASP vulnerable machine) and look for URLs or parameters that could potentially include files dynamically. Look for URLs with parameters like `page=`, `file=`, or `template=`.

Example URL structure that might be vulnerable

<http://owasp-machine.com/index.php?page=home.php>

2. Intercept and Manipulate Parameters in Burp Suite

- While browsing, **intercept the HTTP request** in Burp Suite where a parameter specifies a file path, like `page=home.php`.
- Send this request to **Burp Suite Repeater** by right-clicking on the intercepted request and selecting **Send to Repeater**. This allows for testing various inputs.

3. Test for Directory Traversal in the Parameter

- In the Repeater tab, modify the value of the file parameter to see if directory traversal is possible. For example:

`page=../../../../etc/passwd`

Submit the request by clicking the **Send** button.

Check the response for indications of file inclusion. If successful, you may see the contents of `/etc/passwd` in the response, which lists system users in Linux environments.







